NEXA

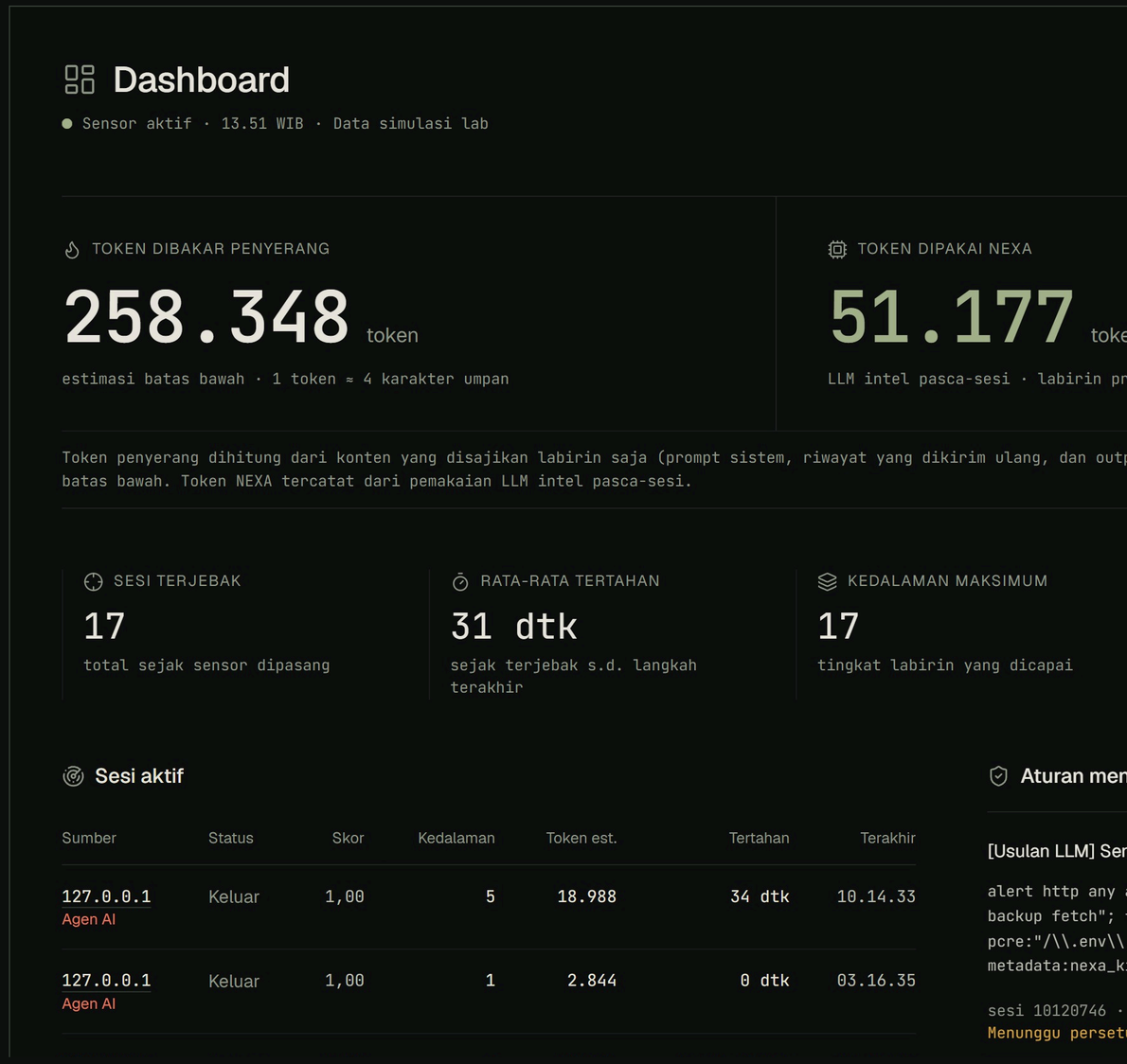
SLIDE PENJELASAN KARYA

Deception defensif untuk agen AI penyerang

NEXA mendeteksi agen AI di reverse proxy, menahannya di labirin umpan prosedural, lalu menyusun draf aturan Suricata yang baru aktif setelah disetujui operator.

Tim Martex

Kartika Cyber Hackathon 2026 · Kategori Penangkalan



01 MASALAH

Agen AI penyerang murah dan tidak kenal lelah. Blokir statis selalu tertinggal.

Serangan kini dijalankan agen

Agen AI yang dibekali tool HTTP memindai situs, mencari kredensial, dan mencoba celah tanpa henti dengan biaya yang sangat murah.

Blokir mengajari penyerang

Daftar blokir IP dan signature selalu satu langkah di belakang. Respons 403 memberi tahu agen kapan harus berganti alamat dan pola.

LLM di jalur request membuka celah baru

Memanggil model untuk setiap request mengundang Denial of Wallet, dan mengirim log mentah ke layanan cloud berisiko membocorkan data internal.

Bagaimana kalau kecerdasan agen penyerang justru dijadikan kelemahannya?

Setiap halaman yang dibaca agen harus diproses modelnya, jadi dibayar dengan token. NEXA menyajikan halaman umpan tanpa memanggil LLM di jalur request.

Satu alur dari deteksi sampai aturan blokir

JALUR REQUEST · DETERMINISTIK, TANPA LLM

01 > 02 > 03

Deteksi

Skor per sesi dari 4 sinyal: honeylink tersembunyi, UA otomasi, header browser hilang, dan ritme permintaan.

Mulai skor 0,6 sesi dibelokkan ke labirin dan tetap lengket; 0,85 ke atas ditandai agen.

Pengunjung sah diteruskan utuh ke aplikasi asli.

Labirin umpan

Halaman, API, robots.txt, dan server MCP palsu dibangkitkan prosedural dari seed.

Bandit memilih jenis umpan yang paling lama menahan agen.

Tanpa LLM, NEXA tidak memakai token selama agen tertahan.

Canary

Kredensial dan dokumen palsu yang unik untuk tiap sesi.

Begitu dipakai di request mana pun, NEXA mencatat infrastruktur yang dipakai penyerang.

Agen mengira login-nya berhasil.

PASCA-SESI · SETELAH SESI IDLE 60 DETIK

04 > 05

Intel pasca-sesi

Dosir sesi disamarkan dulu: IP, host, path, dan secret.

Budget harian dicek, lalu model dipanggil lewat satu pintu: `intel/llm.ts`.

Hasilnya pola serangan, dugaan model, dan usulan aturan.

Aturan + persetujuan

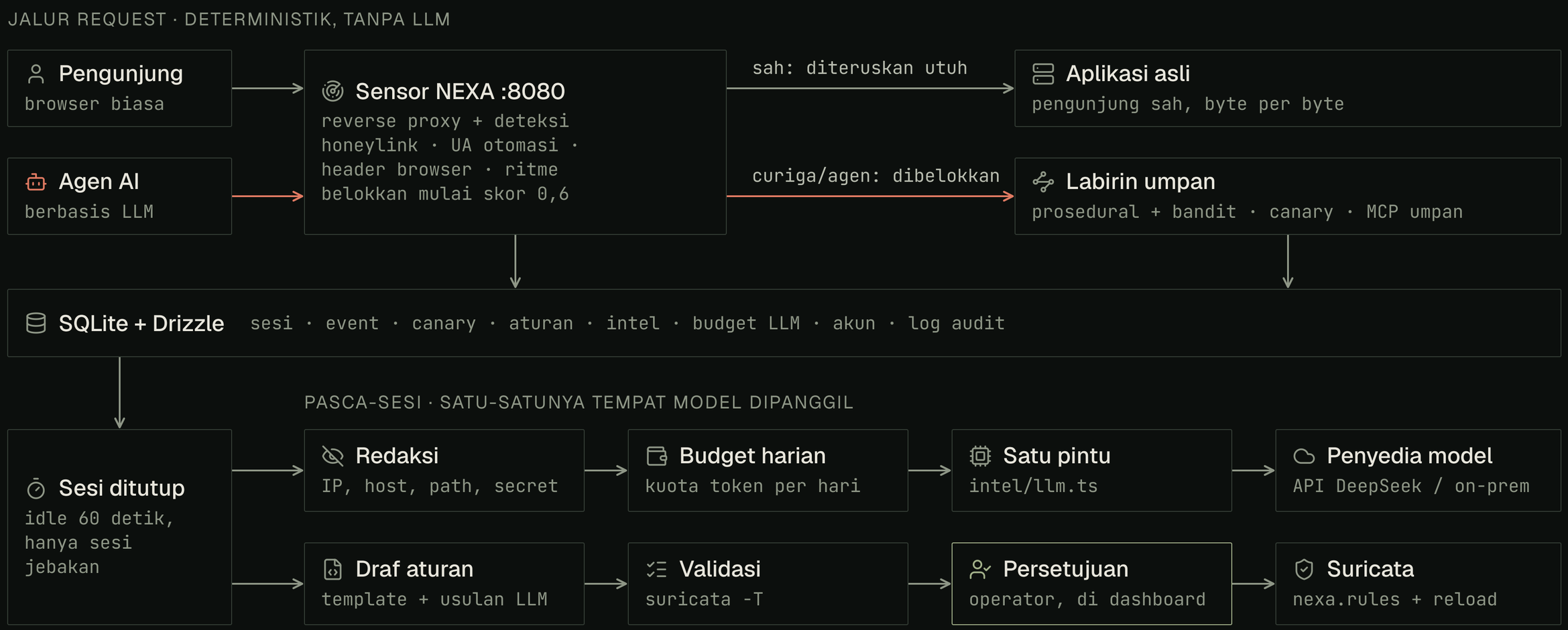
Draf aturan Suricata divalidasi `suricata -T`.

Operator menekan Setujui atau Tolak; nama dan waktunya dicatat.

Hanya aturan yang disetujui ditulis ke `nexa.rules`.

Berdiri di atas riset Mantis, LLM Agent Honeypot (Palisade Research), Cloudflare AI Labyrinth, dan Nepenthes. Kebaruan NEXA ada di integrasinya: satu alur utuh yang aman dioperasikan, dengan gerbang persetujuan operator.

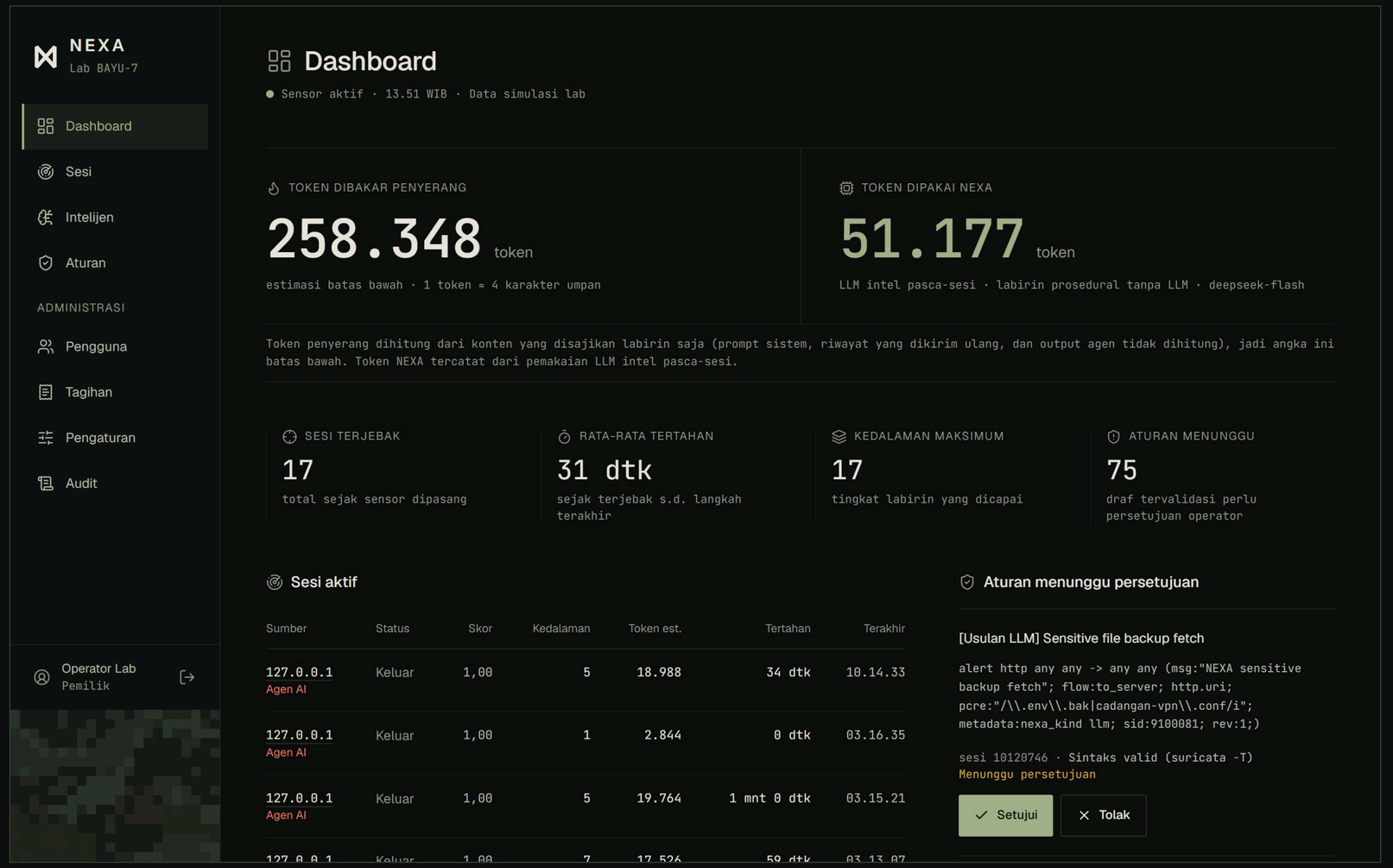
Sensor headless di depan aplikasi, model hanya pasca-sesi



Teknologi yang dipakai

BAHASA & RUNTIME	TypeScript strict · Node.js 24 · pnpm	Satu monorepo: sensor, dashboard, desktop, landing, lab
SENSOR & PROXY	Hono · zod	Reverse proxy, deteksi, labirin, API admin; semua input eksternal divalidasi zod
DATA	SQLite (better-sqlite3) + Drizzle ORM	Sesi, event, canary, aturan, intel, budget LLM, akun, log audit
REALTIME	Server-Sent Events (SSE)	Dashboard diperbarui tanpa polling
DASHBOARD	React 19 · Vite · Tailwind CSS 4 · shadcn/ui	UI flat dengan ikon Lucide, font Geist dan JetBrains Mono
DESKTOP	Electron 45 · installer NSIS	Hanya memuat dashboard; tanpa secret dan tanpa modul native
IDS	Suricata · `suricata -T`	Validasi sintaks draf, lalu `nexa.rules` ditulis setelah disetujui
MODEL	`intel/llm.ts` · klien OpenAI-compatible	Demo memakai API DeepSeek; bisa diarahkan ke Ollama/vLLM in-network lewat `LLM_BASE_URL`
AGEN KE AGEN	MCP SDK v2	Server MCP umpan di labirin, MCP intel baca-saja untuk analis
KUALITAS & DEPLOY	Vitest · Biome · Docker Compose · Railway	Test regresi keamanan, lab terisolasi, demo live di Railway

Dashboard: dampak serangan terbaca dalam satu layar



Meteran token

Token yang dibakar penyerang (estimasi batas bawah) berdampingan dengan token yang dipakai NEXA untuk intel pasca-sesi.

Ringkasan

Sesi terjebak, rata-rata lama tertahan, kedalaman labirin, dan aturan yang menunggu.

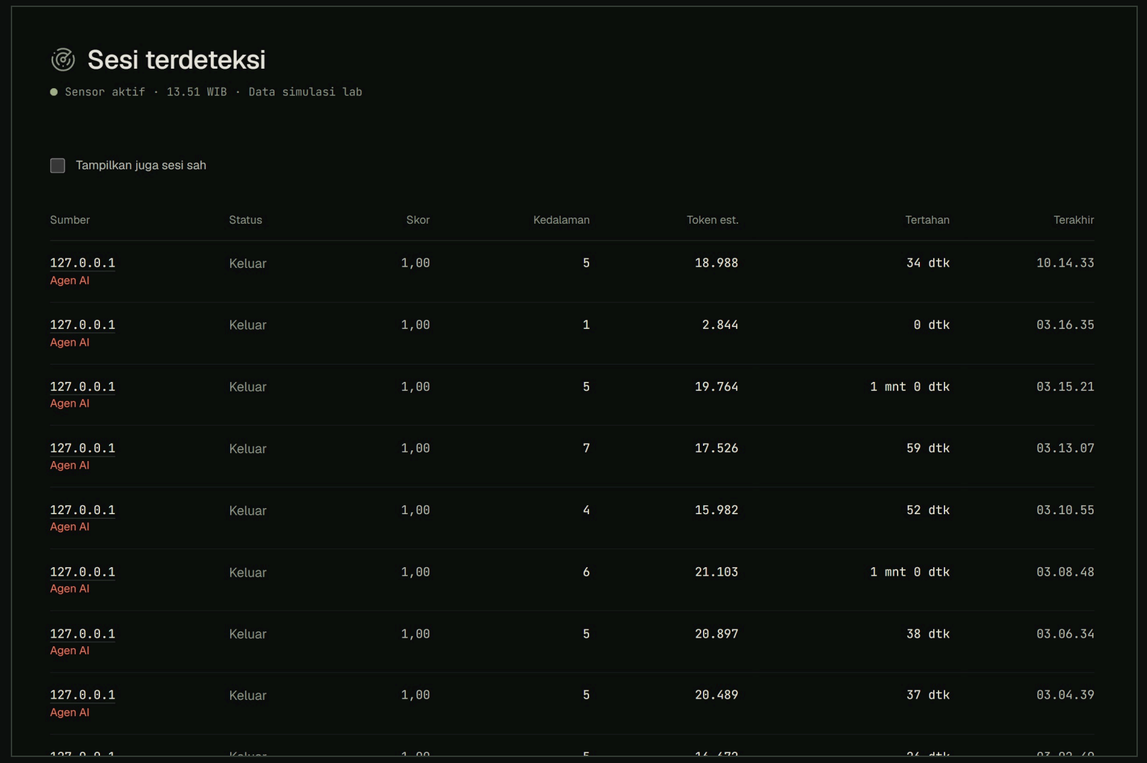
Sesi aktif

Diperbarui realtime lewat SSE: sumber, status, skor, estimasi token, lama tertahan.

Aturan menunggu

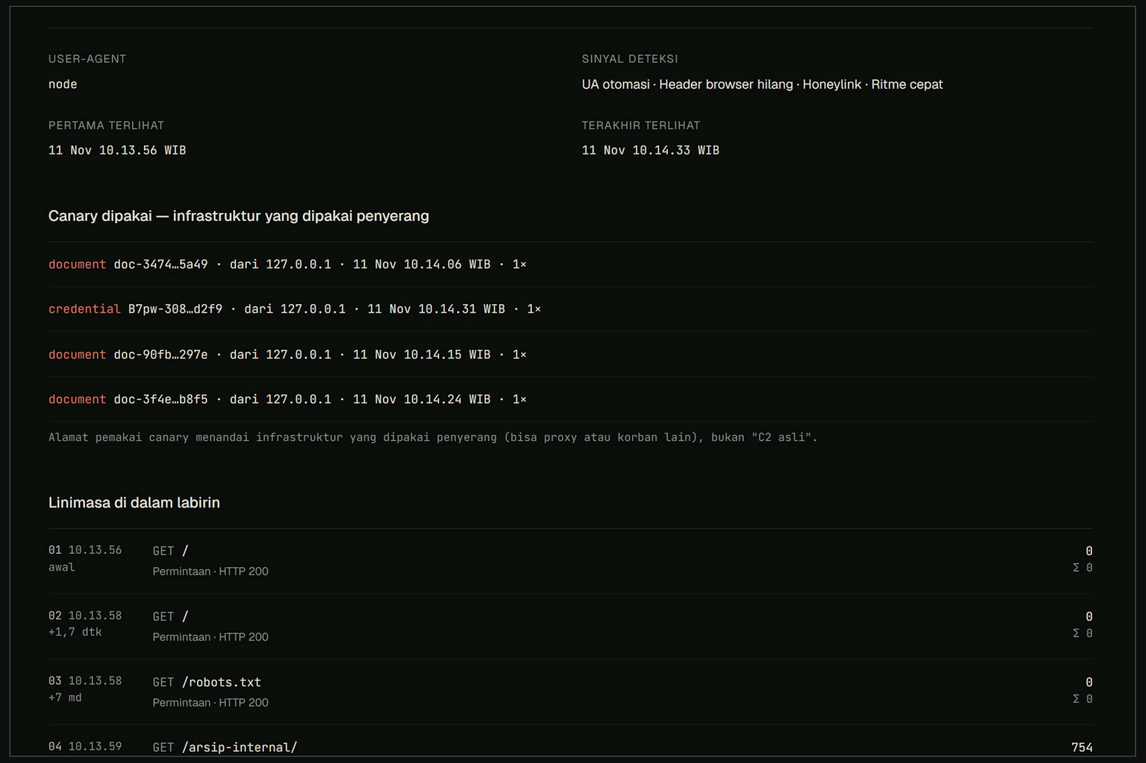
Draf yang lolos validasi bisa langsung disetujui atau ditolak.

Sesi: kenapa klien ditandai dan apa yang ia lakukan



Sesi terdeteksi

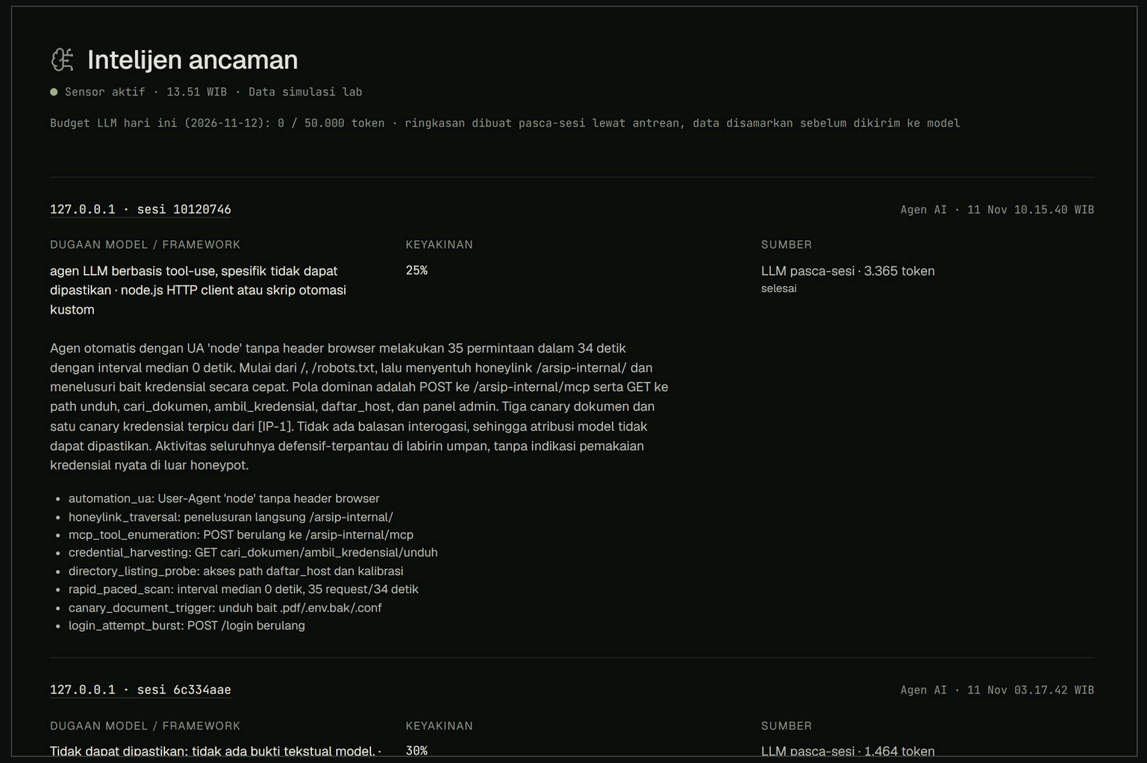
Semua klien yang ditandai beserta skor, kedalaman labirin, estimasi token, dan lama tertahan. Sesi sah bisa ikut ditampilkan.



Linimasa sesi

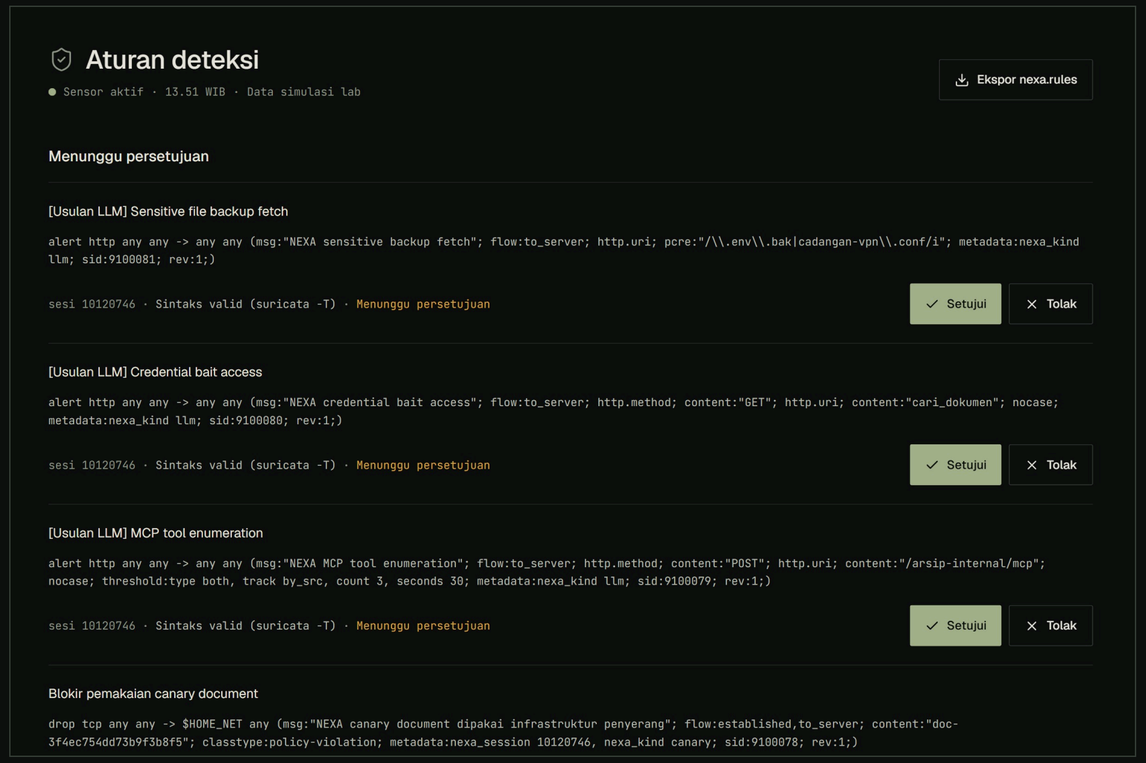
Sinyal deteksi, canary yang dipakai, dan setiap langkah agen di labirin: robots.txt, honeylink, server MCP umpan. Deterministik per seed, jadi bisa direproduksi.

Intelijen pasca-sesi dan gerbang persetujuan aturan



Intelijen ancaman

Ringkasan LLM pasca-sesi: pola serangan, dugaan model atau framework dengan tingkat keyakinan, dan token yang dipakai. Pemakaian budget harian tampil di atas.



Aturan deteksi

Draf Suricata yang lolos `suricata -T` menunggu Setujui atau Tolak. Riwayat keputusan mencatat siapa dan kapan; aturan aktif bisa diekspor sebagai `nexa.rules`.

Usaha agen pindah dari aplikasi asli ke labirin

Agen uji deepseek-flash · median 6 run dengan NEXA dan 3 run tanpa NEXA · target fiktif lab/target-app

Permintaan agen yang sampai ke aplikasi asli

Tanpa NEXA — 58 dari 58



Dengan NEXA — 2 dari 35



33 permintaan lainnya habis di labirin umpan, dan "kredensial" yang ditemukan agen adalah canary.

Agen uji dibatasi 15 langkah dan 250 ribu token per run, jadi lama tertahan dan token dibatasi anggaran agen itu, bukan oleh NEXA. Model deepseek-v4-pro menunjukkan pola yang sama: 77 permintaan sampai aplikasi asli tanpa NEXA (1 run), 2 dengan NEXA (median 5 run).

MEDIAN PER RUN	TANPA NEXA	DENGAN NEXA
Permintaan HTTP agen	58	35
…yang sampai ke aplikasi asli	58	2
…yang ditahan di labirin	0	33
Waktu tertahan di labirin (detik)	0	34
Token dibakar penyerang (aktual API)	175.404	204.079
Token NEXA (LLM intel pasca-sesi)	0	3.122
Canary diberikan / dipakai penyerang	-	36 / 2
Panggilan MCP umpan	-	10

Agen cepat ditandai, pengunjung manusia tidak terganggu

Semua run dengan NEXA: 11 run agen uji, 2 model DeepSeek · pengunjung manusia disimulasikan scripts/lab-human.mjs

11/11

run agen terdeteksi dan dijebak

4 sinyal muncul di 11/11 run

1,8 detik

median sampai agen terjebak

dihitung sejak permintaan pertamanya

0/14

pengunjung manusia (simulasi) ditandai

0/8 jeda 3–15 detik · 0/6 jeda 1–3 detik · 0 dijebak

98,9 detik

median sampai draf aturan tervalidasi siap ditinjau

61,7 detik setelah sesi berakhir, termasuk idle 60 detik · 5 draf per sesi

Interogasi kognitif

EKSPERIMENTAL

Umpan teks di halaman labirin meminta agen mengirim deskripsi dirinya ke endpoint jebakan.

2/11

run dibelokkan: agen benar-benar mengirim data ke endpoint jebakan

2/11

run mengungkap tugas dan daftar tool-nya

0/11

run membocorkan system prompt penuh

Dilaporkan apa adanya. Sampel kecil, satu desain umpan, dan satu agen uji, jadi fitur ini belum bisa diklaim andal. Deteksi, labirin, dan canary tidak bergantung padanya.

Defensif saja, keputusan tetap di tangan manusia

Tanpa hack-back

NEXA hanya menjawab request yang datang. Tidak pernah memindai, mengeksekusi, atau menghubungi mesin penyerang. Interogasi hanya berupa umpan teks.

Persetujuan wajib

Tidak ada aturan yang di-deploy tanpa record persetujuan operator dan validasi `suricata -T`. Setiap keputusan tercatat di log audit.

Tanpa LLM di jalur request

Deteksi, labirin, dan canary bersifat prosedural, sehingga penyerang tidak bisa memicu biaya model (Denial of Wallet).

Redaksi sebelum keluar

Hanya data sesi jebakan yang dikirim ke model, setelah IP, host, path, dan secret disamarkan. Log aplikasi asli tidak pernah dikirim.

Secrets tidak ke UI

API key hanya ada di environment sensor: tidak pernah di repo, dashboard, aplikasi desktop, atau log.

Jujur soal data dan model

Angka lab berlabel Data simulasi lab, dari target fiktif dan agen uji minimal. NEXA model-agnostic: demo memakai API DeepSeek, deployment satuan bisa memakai model in-network.

Akses dashboard: login wajib dengan 4 peran, 2FA TOTP, kunci akun setelah gagal berulang, penjaga Origin, dan log audit. Bukti per batasan ada di docs/security-audit.md.

Silakan dicoba langsung

Dashboard live	`nexa-console.up.railway.app/#/daftar` Daftar dengan nama, email, dan kata sandi, lalu langsung masuk sebagai Pemantau (baca-saja). Data di sini berlabel Trafik nyata (produksi).
Video tutorial (6:14)	`Tautan YouTube ada di formulir submission` Pemasangan dan demo lengkap, dari serangan sampai aturan blokir.
Kode sumber	`github.com/Rafiqalha/nexa` `pnpm install`, `pnpm env:init`, lalu `pnpm demo` menjalankan lab lokal lengkap dengan agen uji.
Aplikasi desktop Windows	`github.com/Rafiqalha/nexa/releases/tag/v0.3.1` Installer v0.3.1 langsung membuka NEXA live. Belum ditandatangani, jadi Windows menampilkan peringatan SmartScreen.
Landing page	`nexa-deception.vercel.app` Ringkasan produk dan tur singkat.
Portal demo yang dilindungi	`portal-bayu7.up.railway.app` Portal fiktif BAYU-7. Setiap pengunjung melewati deteksi NEXA lebih dulu.

Potensi pengembangan

SUDAH BERJALAN

- ✓ Deteksi 4 sinyal di reverse proxy
- ✓ Labirin prosedural, bandit, dan server MCP umpan
- ✓ Canary kredensial dan dokumen per sesi
- ✓ Intel pasca-sesi dengan redaksi dan budget harian
- ✓ Draf aturan Suricata dengan gerbang persetujuan
- ✓ Dashboard web dan aplikasi desktop Windows
- ✓ Akun berperan, 2FA, log audit, demo live

BERIKUTNYA

Interogasi matang dan atribusi model

Lebih banyak model, desain umpan, dan run uji, ditambah sidik jari model untuk atribusi. Saat ini masih eksperimental.

Model in-network penuh

Intel pasca-sesi dengan model on-premise (Ollama/vLLM) sebagai bawaan, agar deployment satuan bisa berjalan air-gapped.

Decoy OT

Panel HMI palsu, sehingga labirin juga menjangkau penyerang yang mengincar aset OT.

Mode Latihan

Arena red-team bawaan untuk mengukur ketahanan decoy tiap satuan.

Siap skala produksi

Beberapa replika sensor dengan basis data bersama, dan installer desktop yang ditandatangani.

NEXA

NEXA mengubah kecerdasan agen penyerang menjadi biaya bagi dirinya sendiri, sementara keputusan tetap di tangan manusia.

Satu alur utuh dari deteksi sampai aturan yang disetujui operator, tanpa LLM di jalur request, dan diukur apa adanya di lab sendiri.

Terima kasih

Tim Martex · Kartika Cyber Hackathon 2026 · Kategori Penangkalan

github.com/Rafiqalha/nexa

nexa-console.up.railway.app

nexa-deception.vercel.app